

# Security+ 1.4 · Public Key Infrastructure (PKI)

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.4 — Public Key Infrastructure (PKI) (9:08)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

---

**Executive Lesson Summary:** PKI is the foundation of modern cryptography, distinguishing symmetric encryption (AES: same key, fast, suitable for bulk data) from asymmetric encryption (RSA/ECC: public/private key pair, slow, ideal for key exchange and digital signatures). Key escrow refers to storing a copy of a key in a secure vault for recovery purposes.

## High-Yield Core Concepts Tested on Exam

---

- AES is symmetric; RSA is asymmetric
- Asymmetric: public key encrypts, private key decrypts (or signs)
- PGP combines both: RSA for key exchange + AES for content encryption
- Key escrow: a copy of the key is stored in a secure vault
- Symmetric encryption is faster and used for bulk data; asymmetric is slower and used for key exchange and signatures

## Exam Tips & Classic Scenarios

---

- 'requires a mathematical relationship between two cryptographic keys' indicates asymmetric (PKI)
- Do not confuse AES with RSA; the exam frequently cites specific algorithms
- Remember: symmetric = same key; asymmetric = key pair

**Typical Exam Scenario:** A company needs to ensure that a message can only be opened by the intended recipient without sharing a password. This requires asymmetric encryption (public/private key pair).

## **Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.4 — Public Key Infrastructure (PKI))**

---

**Why is this advanced coverage required for SY0-701?** Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

### **Classic CompTIA Traps & Question Framing:**

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

## **Practice Questions with In-Depth Solutions (10 Questions)**

---

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

### **1. AES is an example of encryption:**

- A)** Symmetric (same key encrypts and decrypts)
- B)** Asymmetric (key pair)
- C)** One-way hash
- D)** Base64 encoding

### **2. Which type of encryption uses public and private key pairs?**

- A)** Hashing
- B)** Symmetric encryption
- C)** Asymmetric encryption
- D)** Steganography

**3. In a PKI infrastructure, which component is responsible for validating and revoking digital certificates?**

- A)** RA (Registration Authority)
- B)** CA (Certificate Authority)
- C)** CRL (Certificate Revocation List)
- D)** OCSP (Online Certificate Status Protocol)

**4. Exchanging a secret key over a public channel WITHOUT sending it directly uses:**

- A)** Diffie-Hellman
- B)** AES
- C)** SHA-256
- D)** Base64

**5. Service that manages encryption keys in the cloud (create, rotate, control access):**

- A)** KMS (Key Management Service)
- B)** IAM
- C)** CDN
- D)** VPC

**6. Corporate scenario (Public Key Infrastructure (PKI)): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'AES = symmetric; RSA = asymmetric'. What is the best recommendation or applicable control classification?**

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: AES = symmetric; RSA = asymmetric...

**7. Corporate scenario (Public Key Infrastructure (PKI)):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Asymmetric: public encrypts, private decrypts (or signs)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Asymmetric: public encrypts, private decrypts (or signs)
- D)** Allow shared access among administrators using generic credentials

**8. Corporate scenario (Public Key Infrastructure (PKI)):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'PGP: combines both (RSA to exchange the key + AES for the content)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: PGP: combines both (RSA to exchange the key + AES for the content).
- D)** Allow shared access among administrators using generic credentials

**9. Corporate scenario (Public Key Infrastructure (PKI)):** During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'requires a mathematical relationship between two cryptographic keys' = asymmetric (PKI). What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'requires a mathematical relationship between two cryptographic keys' = asymmetric (PKI)

**10.** Corporate scenario (Public Key Infrastructure (PKI)): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'AES vs RSA: do not confuse them — the exam likes to cite algorithms.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: AES vs RSA: do not confuse them — the exam likes to cite algorithms.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

## COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

### 1) A — Symmetric (same key encrypts and decrypts).

✓ **Why it's correct:** The correct answer is 'Symmetric (same key encrypts and decrypts)'. AES (Advanced Encryption Standard) is a symmetric encryption algorithm, meaning the same key is used to both encrypt and decrypt data. It is a widely adopted standard, with key sizes of 128, 192, or 256 bits, and is considered secure and efficient. CompTIA Security+ SY0-701, in the Security Implementation domain (3.3), lists AES as an example of symmetric encryption. The question asks for the correct classification of AES, which is symmetric.

#### ✗ **Why the others are wrong:**

- *Asymmetric (key pair):* Asymmetric encryption uses a key pair: a public key to encrypt and a private key to decrypt (or vice versa for signatures). Examples include RSA, ECC, and Diffie-Hellman. AES is not asymmetric; it uses a single shared secret key. Therefore, this option is incorrect.
- *One-way hash:* Cryptographic hash functions, such as SHA-256 and MD5, are one-way: they transform input data into a fixed-size output, with no possibility of reversal. They do not use a key and serve for integrity, not confidentiality. AES is a reversible cipher algorithm with a key, not a hash. Therefore, this option is incorrect.
- *Base64 encoding:* Base64 is an encoding that represents binary data in ASCII format, used to transmit data in environments that only support text. It is not encryption, as it does not use a key and is easily reversible. AES is a cryptographic algorithm, not an encoding. Therefore, this option is incorrect.

### 2) C — Asymmetric encryption.

✓ **Why it is correct:** The correct answer is 'Asymmetric encryption'. Asymmetric encryption, also called public-key cryptography, uses a mathematically related key pair: a public key, which can be freely distributed, and a private key, kept secret by the owner. The public key is used to encrypt data or verify digital signatures, while the private key is used to decrypt or sign. Examples include RSA, ECC, and Diffie-Hellman. CompTIA Security+ requires understanding that asymmetry solves the key distribution problem and provides confidentiality, integrity, authentication, and non-repudiation.

#### ✗ **Why the others are wrong:**

- *Hashing:* Hashing is a one-way cryptographic function that transforms an input of variable length into a fixed-length output (digest). It does not use keys and is not used to encrypt/decrypt data, but rather to verify integrity. This option is incorrect because hashing does not involve key pairs and does not provide confidentiality.
- *Symmetric encryption:* Symmetric encryption uses a single shared secret key between parties to encrypt and decrypt. Examples: AES, DES, 3DES. Although efficient, it does not use a public and private key pair. This option is incorrect because it describes the single-key model, not the asymmetric model.
- *Steganography:* Steganography is the art of hiding information within other files (images, audio, video) so that the existence of the message goes unnoticed. It does not involve public or private key cryptography. This option is incorrect because it is not a key-based cryptographic method, but rather a concealment technique.

### 3) B — CA (Certificate Authority).

✓ **Why it's correct:** The \*\*CA (Certificate Authority)\*\* is the central component of a PKI responsible for issuing, validating, and revoking digital certificates. It digitally signs certificates,

ensuring the authenticity and integrity of public keys. Additionally, the CA maintains and publishes the CRL (Certificate Revocation List) and/or provides the OCSP (Online Certificate Status Protocol) service so that third parties can verify whether a certificate is still valid. In the CompTIA Security+ (SY0-701) syllabus, the CA is described as the trusted entity that validates identities and manages the certificate lifecycle, including revocation. Therefore, the CA is the exact answer for 'validating and revoking digital certificates'.

**✗ Why the others are wrong:**

- *RA (Registration Authority)*: The RA (Registration Authority) is an entity subordinate to the CA that acts as an intermediary in the user registration process. Its main function is to verify the identity of the requester before forwarding the certificate request to the CA, but it does not issue, validate, or revoke certificates. The RA may assist in collecting documentation and initial authentication, but the final decision to issue and revoke is always the CA's. In the context of the question, the RA does not perform certificate validation and revocation; it only facilitates registration, so it is incorrect.
- *CRL (Certificate Revocation List)*: The CRL is a list periodically published by the CA containing the serial numbers of certificates that have been revoked before their expiration date. It is a lookup mechanism to check whether a certificate is revoked, but it does not perform validation or revocation itself. The CRL is an artifact generated by the CA; it does not make decisions or execute revocation actions. Furthermore, validating a certificate involves verifying the CA's signature, the chain of trust, and temporal validity, which is not done by the CRL. Therefore, CRL is only a lookup tool, not the component responsible for validation and revocation.
- *OCSP (Online Certificate Status Protocol)*: OCSP is a real-time query protocol that allows checking whether a specific certificate has been revoked by querying the CA or an OCSP responder directly. It offers a faster alternative to the CRL, but it is not the component that validates or revokes certificates; it is only a status-checking service. The responsibility for issuing, validating, and revoking certificates remains with the CA. OCSP depends on the CA to obtain revocation information. Thus, it is not the correct answer for the function of validating and revoking certificates.

**4) A — Diffie-Hellman.**

✓ **Why it is correct:** The Diffie-Hellman (DH) algorithm and its ephemeral variants (DHE, ECDHE) allow two parties to establish a shared secret key over an insecure public channel without ever transmitting the key directly. Each party generates a key pair (private and public), exchanges public keys, and using their private key and the other party's public key, computes the same secret. An observer who intercepts the public keys cannot derive the secret due to the difficulty of the discrete logarithm problem (or elliptic curve discrete logarithm). This secret is then used to derive symmetric session keys, ensuring confidentiality even on untrusted networks.

**✗ Why the others are wrong:**

- *AES*: AES (Advanced Encryption Standard) is a symmetric block cipher used to encrypt bulk data with a pre-shared secret key. It does not solve the problem of establishing that initial secret key over a public channel; if the AES key were sent directly, an interceptor would capture it and could decrypt all communication. AES is the end recipient of the secret generated by Diffie-Hellman, not the exchange mechanism itself.
- *SHA-256*: SHA-256 is a cryptographic hash function that produces a 256-bit digest from an input, used for integrity verification and digital signatures. It is not a key agreement protocol and does not generate shared secrets between parties. Applying SHA-256 to a key does not make it secret; the hash is one-way, but it does not prevent an attacker who sees the original input from discovering the key. Therefore, SHA-256 does not replace Diffie-Hellman in secure key exchange.

- *Base64*: Base64 is an encoding of binary data into ASCII text, used to transport information in text-based protocols (such as MIME email). It is not encryption or key agreement; it is a reversible transformation without a key. Anyone can trivially decode Base64. Using Base64 to 'exchange a secret key' would mean sending it in clear text disguised, completely violating the requirement not to transmit it directly and exposing the secret to any interceptor.

#### 5) A — KMS (Key Management Service).

✓ **Why it is correct:** KMS (Key Management Service) is a managed encryption service offered by cloud providers (AWS KMS, Azure Key Vault, Google Cloud KMS) that centralizes the complete lifecycle of cryptographic keys: generation, secure storage, automatic rotation, granular access policies via IAM, and usage auditing. In the context of CompTIA Security+ (domain 3.4 - 'Given a scenario, apply cybersecurity solutions to the cloud'), KMS is the standard solution for managing encryption keys in cloud environments, enabling data at rest (EBS, S3, RDS) and in transit to be protected with customer-managed or provider-managed keys. It exactly meets the requirement to 'create, rotate, and control access' to keys, making it the correct answer.

#### ✗ **Why the others are wrong:**

- *IAM*: IAM (Identity and Access Management) is a service for managing identities and permissions that controls who can access which cloud resources, defining users, groups, roles, and policies. Although IAM is used to authorize access to KMS, it does not manage cryptographic keys itself — it does not create, rotate, or store keys. Therefore, it is incorrect for the question, which specifically asks for the key management service.
- *CDN*: CDN (Content Delivery Network) is a distributed network of edge servers that caches static content (images, videos, scripts) to reduce latency and improve delivery to users. It has no relation to cryptographic key management; its function is performance optimization and availability, not key security. Thus, it does not meet the requirement.
- *VPC*: VPC (Virtual Private Cloud) is an isolated virtual network within the cloud, where the user defines subnets, route tables, gateways, and security groups. It is a network infrastructure service, not a key management service. Although it can host instances that use KMS, the VPC itself does not create, rotate, or control cryptographic keys. Therefore, it is incorrect for the question.

#### 6) D — Implement the corresponding solution: AES = symmetric; RSA = asymmetric....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Public Key Infrastructure (PKI)): AES = symmetric; RSA = asymmetric. AES (Advanced Encryption Standard) is a symmetric encryption algorithm using the same key for encryption and decryption, while RSA is an asymmetric algorithm using a public-private key pair.

#### ✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

#### 7) C — Implement the corresponding solution: Asymmetric: public encrypts, private decrypts (or signs).

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for

lesson 1.4 (Public Key Infrastructure (PKI)): Asymmetric: public encrypts, private decrypts (or signs). This is a fundamental concept of asymmetric encryption.

**✗ Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

**8) C — Implement the corresponding solution: PGP: combines both (RSA to exchange the key + AES for the content)..**

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Public Key Infrastructure (PKI)): PGP: combines both (RSA to exchange the key + AES for the content). PGP (Pretty Good Privacy) uses a hybrid cryptosystem: asymmetric encryption (e.g., RSA) to securely exchange a symmetric session key, and symmetric encryption (e.g., AES) to encrypt the actual message content for efficiency. This combines the strengths of both cryptographic methods.

**✗ Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

**9) D — Implement the corresponding solution: 'requires a mathematical relationship between two cryptographic keys' = asymmetric (PKI).**

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Public Key Infrastructure (PKI)): 'requires a mathematical relationship between two cryptographic keys' = asymmetric (PKI).

**✗ Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

**10) B — Implement the corresponding solution: AES vs RSA: do not confuse them — the exam likes to cite algorithms..**

✅ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Public Key Infrastructure (PKI)): AES vs RSA: do not confuse them — the exam likes to cite algorithms. AES is a symmetric block cipher used for bulk data encryption, while RSA is an asymmetric algorithm used for key exchange, digital signatures, and encryption of small data. Understanding their distinct roles is critical for PKI and cryptographic implementations.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.